

Délibération SAN-2023-023 of December 29, 2023

National Commission for Information Technology and Liberties

Nature of the deliberation: Sanction

Legal status: In force

Date of publication on Légifrance: Thursday, January 11, 2024

Deliberation of the restricted formation No. SAN-2023-023 of December 29, 2023, concerning the company NS CARDS FRANCE

The National Commission for Information Technology and Liberties, convened in its restricted formation composed of Mr. Alexandre LINDEN, president, Mr. Philippe-Pierre CABOURDIN, vice-president, Mr. Alain DRU, and Ms. Isabelle LATOURNARIE-WILLEMS, members;

Considering Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of personal data and the free movement of such data;

Considering Directive 2002/58/EC of the European Parliament and of the Council of July 12, 2002, concerning the processing of personal data and the protection of privacy in the electronic communications sector;

Considering Law No. 78-17 of January 6, 1978, relating to information technology, files, and freedoms, particularly its Articles 20 and following;

Considering Decree No. 2019-536 of May 29, 2019, amended, taken for the application of Law No. 78-17 of January 6, 1978, relating to information technology, files, and freedoms;

Considering Deliberation No. 2013-175 of July 4, 2013, adopting the internal regulations of the National Commission for Information Technology and Liberties;

Considering Decision No. 2021-193C of June 29, 2021, of the president of the National Commission for Information Technology and Liberties, charging the Secretary General to carry out or have carried out a verification mission of the personal data processing implemented by the company or on its behalf;

Considering the decision of the president of the National Commission for Information Technology and Liberties designating a rapporteur before the restricted formation, dated March 29, 2022;

Considering the report of Mr. François PELLEGRINI, rapporteur commissioner, notified to the company NS CARDS FRANCE on July 3, 2023;

Considering the written observations submitted by the company NS CARDS FRANCE on August 18, 2023;

Considering the other documents in the file;

Present at the session of the restricted formation on November 16, 2023:

- Mr. François PELLEGRINI, commissioner, heard in his report;

As representatives of the company NS CARDS FRANCE:

- [...];

- [...];

- [...];

The company NS CARDS FRANCE having spoken last;

The restricted formation adopted the following decision:

I. Facts and Procedure

1. The company NS CARDS FRANCE (hereinafter "the company"), whose registered office is located at 10, rue Vandrezanne in Paris (75013), was registered in the trade and companies register on November 9, 2010. In 2019, its turnover amounted to [...] euros with a net profit of [...] euros, and in 2020, its turnover amounted to [...] euros with a net profit of [...] euros. In 2023, it had six employees.

2. The company NS CARDS FRANCE is an electronic money distributor that enables online payments. The company offers two forms of payment solutions: on one hand, it distributes neosurf vouchers at authorized points of sale, through which individuals can make online payments on partner websites; on the other hand, the use of neosurf vouchers can also be linked to the creation of an electronic wallet, which requires creating a user account on the website www.neosurf.com or the mobile application

"neosurf" and funding it using vouchers or a credit card. The creation of a user account allows for online payments or receiving winnings. It is this second activity that is at issue in the present procedure.

3. Two control missions took place under Decision No. 2021-193C of June 29, 2021, of the president of the CNIL to verify the company's compliance with all provisions of Regulation (EU) 2016/679 of the European Parliament.

European and Council Regulation of April 27, 2016 (hereinafter "the GDPR") and Law No. 78-17 of January 6, 1978 relating to information technology, files, and freedoms as amended (hereinafter "the Data Protection Act"). On September 24, 2021, the services of the CNIL conducted an online inspection from the website "www.new.neosurf.com". On October 13, 2021, the services of the CNIL carried out an on-site inspection at the premises of NS CARDS FRANCE, located in Paris (75013).

4. The online inspection of the website www.new.neosurf.com (now www.neosurf.com) primarily aimed to verify the information provided to individuals and the procedure for creating a user account. It allowed for the observation of the deposit of cookies and other trackers via the said website. The on-site inspection specifically focused on verifying the documentation required by the GDPR, the process of creating an account on the neosurf mobile application, the retention periods applied to user account data, as well as the technical and organizational measures intended to ensure the security of the data collected through the website and the mobile application.

5. These two inspection missions resulted in the establishment of reports No. 2021-193/1 and 2021-193/2. By letters dated October 8, October 22, and November 15, 2021, the company provided additional elements to the Commission's services.

6. In accordance with Article 56 of the GDPR, the CNIL informed all European supervisory authorities on May 10, 2023, of its competence to act as the lead supervisory authority concerning cross-border processing carried out by the company, resulting from the fact that the company's single establishment is located in France. After exchanges between the CNIL and European data protection authorities within the framework of the one-stop-shop mechanism, it appears that the German, Austrian, Belgian, Cypriot, Danish, Spanish, Finnish, Greek, Irish, Italian, Luxembourgish, Dutch, Norwegian, Polish, Portuguese, Romanian, and Swedish authorities are concerned by the processing, as user accounts have been created by residents of these states.

7. For the purpose of investigating these elements, the President of the Commission designated Mr. François PELLEGRINI as the rapporteur on March 29, 2022, based on Article 22 of the Data Protection Act.

8. On July 3, 2023, the rapporteur notified the company of a report detailing the breaches of Articles 5-1-e), 12, 13, and 32 of the GDPR as well as Article 82 of the Data Protection Act, which he deemed constituted in this case.

9. On August 18, 2023, the company submitted its observations in response to the sanction report.

10. By letter dated September 29, 2023, the rapporteur informed the company's counsel that the investigation was closed, in accordance with Article 40, III, of the amended decree No. 2019-536 of May 29, 2019.

11. By letter dated October 2, 2023, the company was informed that the case was scheduled for the agenda of the restricted formation on November 16, 2023.

12. The rapporteur and the company presented oral observations during the session of the restricted formation.

II. Reasons for the Decision

A. On the European Cooperation Procedure

13. In accordance with Article 60 paragraph 3 of the GDPR, the draft decision adopted by the restricted formation was transmitted on November 29, 2023, to the concerned European supervisory authorities.

14. As of December 28, 2023, none of the concerned supervisory authorities had raised any relevant and reasoned objections to this draft decision, so that, in accordance with Article 60, paragraph 6, of the GDPR, they are deemed to have approved it.

B. On the breach of the obligation to limit the retention period of data

15. Under Article 5-1, e) of the GDPR, personal data must be "kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed."

****allowing the identification of the concerned individuals****

for a duration not exceeding that necessary for the purposes for which they are processed.

16. The rapporteur noted that when creating a user account on the website www.neosurf.com, the name, first name, date of birth, postal address, email address, phone number, and, where applicable, bank details were collected, as well as personal documents such as identity and residence proofs. However, the rapporteur observed from the on-site inspection that while the company had defined a retention period of ten years for this data from the date of the last operation performed on the account, in practice, the accounts were only deactivated at the end of this period, while this data was retained in the production database for an indefinite duration. He also noted that no purging had been carried out in the company's databases since the beginning of its activity in 2005. The rapporteur particularly estimated that the company's letter dated November 15, 2021, indicated the retention of 70,049 inactive accounts for more than ten years. Furthermore, he estimated that the company did not justify the application of the new retention period of five years that it defined following the CNIL inspections for user account data. Finally, he noted that 51,735 accounts were retained without purpose, as they were "unconfirmed," meaning that the email address had not been confirmed at the time of account creation.

17. In defense, during the investigation, the company first indicated that it had defined a retention period of ten years for user accounts for the purposes of combating money laundering and the financing of terrorism ("AML-CFT") before stating, in its letter dated November 15, 2021, that this duration was now only applied to customer contracts concluded for an amount exceeding €120 excluding tax, in accordance with Article D. 213-1 of the Consumer Code, and that other user account data would henceforth be retained for five years from the date of the last operation performed on the account. In its response observations, the company further corrected the statements made during the investigation regarding the applicable duration for the retention of certain data for AML-CFT purposes, which is five years in accordance with Article 561-2 of the Monetary and Financial Code. The company argues that the request provided regarding the 70,049 inactive accounts would show the presence of these accounts in the database for ten years and not for more than ten years. It specifies that this request was solely intended to demonstrate the effective application of the new retention period of five years that it had defined. In its observations, the company provides a new screenshot that would unambiguously attest to the deletion of accounts inactive for five years.

18. Regarding the 51,735 unconfirmed accounts, the company claims that the data associated with these accounts are retained for one year and then deleted if the account is not confirmed. It states that the purpose pursued by this retention is to allow users to have adequate time to confirm their account and reproaches the rapporteur for having prejudged an excessive retention of data associated with unconfirmed accounts, without even questioning it about the purpose of the processing and the retention period applied to this data.

19. The restricted panel recalls, on the one hand, that the retention period for personal data must be determined based on the purpose pursued by the processing. When they are no longer necessary for the purpose for which they were collected, the data must either be deleted or subject to intermediate archiving when their...

****Conservation is necessary for compliance with legal obligations or for pre-litigation or litigation purposes. The data placed in intermediate archiving is retained for a duration not exceeding that**

necessary for the purposes for which it is kept, in accordance with applicable provisions. Thus, after sorting the relevant data to be archived, the data controller must provide, for this purpose, a dedicated archive database or a logical separation within the active database. This logical separation is ensured by implementing technical and organizational measures that guarantee that only individuals with a legitimate interest in processing the data due to their functions can access it. Beyond these durations of intermediate archiving, personal data must, unless exceptions apply, be deleted or anonymized (CNIL, FR, September 8, 2022, Sanction, Groupement X, No. SAN-2022-018, published).**

20. Furthermore, pursuant to Article L. 213-1 of the Consumer Code: "When the contract is concluded electronically and concerns an amount equal to or greater than a sum set by decree, the professional contractor ensures the retention of the written document that records it for a period determined by this same decree and guarantees access to it at any time to its contracting party if requested." Article D. 213-1 of the same code provides that "[t]he amount mentioned in Article L. 213-1 is set at 120 euros," and Article D. 213-2 states that "[t]he period mentioned in Article L. 213-1 is set at ten years from the conclusion of the contract when the delivery of the good or the execution of the service is immediate. Otherwise, the period runs from the conclusion of the contract until the date of delivery of the good or the execution of the service and for a duration of ten years from that date."

21. In this case, the restricted panel first notes, regarding the retention of 51,735 unconfirmed accounts in the database, that while the company's letter dated November 15, 2021, indicated that the data of "inactive prospects" would be deleted after one year, the retention policy attached to this letter paradoxically provided for a retention period of three years for data related to the "management of non-client prospect files." During the hearing, the company explained this contradiction by stating that the three-year retention period was intended solely for the purpose of commercial prospecting and that it was no longer engaged in such activities. In any case, the restricted panel considers that in its defense observations, the company justifies a duration and purpose for the retention of unconfirmed account data, namely, a retention of one year to allow the individuals concerned to have adequate time to confirm their account. Therefore, it considers that the elements of the file do not characterize a breach of Article 5-1-e) of the GDPR on this point.

22. Next, the restricted panel notes that at the time of the on-site inspection, the company had defined a duration of ten years, which begins to run from the date of activation of the user account. Nevertheless, it notes that at the end of this period, user accounts were deactivated, but the company continued to retain the data of the accounts in the database for an indefinite period. The restricted panel further notes that according to the company's own statements, no data purging had been carried out since 2005.

23. Regarding the retention of 70,049 inactive accounts, the restricted panel notes that the screenshot provided by the company in its letter dated November 15, 2021, was intended to illustrate, at the request of the CNIL services, "the number of inactive accounts created more than 10 years prior to October 13, 2021."

The restricted panel considers that, in light of the explanations provided by the company, the screenshot produced showed the retention of inactive accounts for ten years and not for more than ten years. 24. Nevertheless, the restricted panel notes that it follows from the above that when the retention period is reached, personal data must be deleted or anonymized, and that rendering an account inactive does not correspond to either the deletion of the personal data it contains or to anonymization. Consequently, it appears from the documents in the file that as of the date of the on-site inspection, the company retained user account data, even for inactive accounts, for an indefinite period. 25. In any case, the restricted panel observes that it follows from the aforementioned screenshot as well as other elements of the file that until the inspections carried out by the agents of the CNIL, the data of 70,049 customer accounts had been present in the database for ten years without any sorting having been carried out between the data to be retained in accordance with the provisions of Article D. 213-1 of the Consumer Code and those to be deleted. The restricted panel notes that the retention period of five years for data other than that referred to in this provision was only defined at the end of the on-site inspection, as confirmed by the company in its letter of November

15, 2021, and that proof of its effective application was only provided in the context of its observations in defense on August 18, 2023. Therefore, the restricted panel considers that the company retained data from accounts not covered by Article D. 213-1 of the Consumer Code for excessive durations. 26. Consequently, the restricted panel considers that the preceding facts constitute a breach of Article 5-1-e) of the GDPR. The restricted panel notes that the company has come into compliance during the procedure with the establishment and application of adequate retention periods for user account data, in light of the various purposes pursued. However, it reminds that this compliance cannot exempt the company from its liability for the past. C. On the breach of the obligation to inform individuals 27. Under Article 12 of the Regulation, the data controller must provide the individuals concerned with the information specified in Article 13 of the same Regulation "in a concise, transparent, understandable, and easily accessible manner, using clear and simple terms [...]". 28. Article 13 of the GDPR lists the information that must be provided to the individual concerned when personal data is collected directly from them. This information notably includes the identity of the data controller and their contact details, the purposes of the processing carried out, its legal basis, the recipients or categories of recipients of the data, and whether the data controller intends to carry out a transfer of data to a third country. The article also requires the data controller, when necessary to ensure "fair and transparent processing" of personal data in this case, to inform individuals about the retention period of the data, the existence of various rights that individuals have, the existence of the right to withdraw consent at any time, and the right to lodge a complaint with a supervisory authority. 29. The Regulation does not prescribe the form in which this information must be provided. In practice, this information is generally grouped within a privacy policy. 30. In its report, the rapporteur essentially notes that the information provided by the company on the website www.neosurf.com and on its mobile application via the privacy policy was incomplete, outdated, and

only in English. The rapporteur notes, however, that the company has, since the inspections, engaged in a compliance process, without this affecting the breaches that occurred in the past. 31. In its defense, the company does not contest the breach but indicates that it has come into compliance since the inspections. It criticizes the rapporteur for basing certain grievances in his report on informal checks during which he allegedly found that deficiencies persisted at the time of the report's submission, outside of any findings formally recorded in a contradictory report. 32. The restricted panel first notes that it emerges from the findings made during the inspections that regarding the website www.neosurf.com, a privacy policy available at the bottom of the homepage was only available in English. In this regard, it notes, like the rapporteur, that the information provided through a privacy policy available only in English, relating to data processing primarily targeting a French-speaking audience, does not allow the concerned individuals to appreciate in advance the scope and consequences of the processing and is therefore not compliant with the transparency requirements set out in Article 12 of the GDPR. The restricted panel considers that the same applies to the reference made to the privacy policy only in English from the account creation form. 33. Next, the restricted panel notes that both the homepage of the website and the user account creation page referred to versions of the privacy policy from 2018 and 2021, which did not mention the data retention period or the right to lodge a complaint with the CNIL. The restricted panel notes that given the data processed by the company, including bank details, this information was necessary to ensure fair and transparent processing within the meaning of Article 13(2) of the GDPR. It further notes, like the rapporteur, that the coexistence of these two incomplete versions of the privacy policy was likely to create confusion among the concerned individuals regarding the extent of the rights they had concerning their data and the consequences of its processing. 34. Regarding the neosurf mobile application, the restricted panel notes that at the time of the inspections, the account creation page also offered an incomplete privacy policy dated 2018, available only in English, similarly disregarding Articles 12 and 13 of the GDPR for the reasons already discussed regarding the website. 35. Consequently, the restricted panel considers that the company has committed a breach of Articles 12 and 13 of the GDPR. It specifies that the breach taken into account is that which was crystallized at the time of the inspections and that the rapporteur's informal checks preceding the notification of his report were solely intended to draw the company's attention to the fact that its compliance had not yet been achieved. The restricted panel acknowledges that the company has come into compliance. D. On breaches of the obligation to ensure

data security 36. Under Article 32 of the GDPR, "1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing as well as the risks, the likelihood and severity of which vary, for the rights and freedoms of natural persons, the data controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, including, among other things, as necessary: a) the pseudonymization and encryption of personal data; b) means allowing for...

guarantee the confidentiality, integrity, availability, and constant resilience of processing systems and services; c) means to restore the availability of personal data and access to it within appropriate timeframes in the event of a physical or technical incident; d) a procedure aimed at regularly testing, analyzing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

1. On user account passwords

37. To propose to the restricted formation that the company had failed to meet its obligations under Article 32 of the GDPR, the rapporteur noted that during the online inspection, the delegation first observed that when creating a user account on the company's website, passwords of six characters composed of three categories of characters (uppercase letters, lowercase letters, and numbers) were accepted and that no access restrictions were implemented in the event of authentication failure. Furthermore, it was noted that 49,214 passwords were stored in plain text within the company's database and associated with their email address as well as their identifier. Finally, the rapporteur noted that passwords that were not stored in plain text were hashed and salted using the SHA-1 function, which is considered obsolete.

38. In defense, the company does not contest the breaches but states that it has taken corrective actions. First, it announces that it has adapted its password policy to achieve the minimum entropy rate of 50 bits recommended by the CNIL when this password is accompanied by an access restriction measure and indicates that the implementation of these new measures was completed in August 2023. It further criticizes the rapporteur for relying on informal checks that would have allowed him to observe an entropy that was still insufficient at the date of the report's submission. Next, the company specifies that access to plain text passwords was due to technical constraints related to the implementation of password encryption measures for old accounts created at the beginning of its activity and that as of the date of its observations in defense, all passwords are encrypted within the database. Finally, the company acknowledges the rapporteur's conclusions regarding the use of the SHA-1 hashing algorithm and announces that it has opted to switch to the SHA-512 standard, effective since July 2023.

39. Firstly, the restricted formation recalls that it follows from the provisions of Article 32 of the GDPR that the data controller is required to ensure that the automated processing of data it implements is sufficiently secure. The sufficiency of security measures is assessed, on the one hand, in light of the characteristics of the processing and the risks it entails, and on the other hand, taking into account the state of knowledge and the cost of the measures.

40. The restricted formation first considers that overly permissive password complexity rules, which allow the use of insufficiently robust passwords, can lead to attacks by unauthorized third parties, such as "brute force" or "dictionary" attacks, which consist of systematically testing numerous passwords and thus lead to the compromise of associated accounts and the personal data they contain.

41. It notes, in this regard, that the necessity of a strong password is recommended both by the National Cybersecurity Agency (ANSSI) and by the Commission in its deliberation No. 2017-012 of January 19, 2017, adopting a recommendation regarding passwords, a requirement confirmed in its deliberation No. 2022-100 of July 21, 2022.

42. By way of illustration, the rapporteur recalls that the

****Commission considers in its deliberation No. 2017-012 of January 19, 2017**** – which is certainly not imperative but provides relevant insight into the measures to be taken regarding security – that, to ensure a sufficient level of security and confidentiality, in the event that authentication relies solely on a

username and password, the latter must consist of at least twelve characters including uppercase letters, lowercase letters, numbers, and special characters.⁴³ Failing that, the Commission considers that an authentication relying on a password of a minimum length of eight characters, composed of three different categories of characters but accompanied by a complementary measure such as, for example, account access throttling after several failures (temporary suspension of access whose duration increases with each attempt), the implementation of a mechanism to guard against automated and intensive submission of attempts (e.g., "captcha"), and/or account blocking after several unsuccessful authentication attempts (up to a maximum of ten) also ensures a sufficient level of security and confidentiality.⁴⁴ The restricted formation emphasizes that it has, on several occasions, imposed financial sanctions where the characterization of a breach of Article 32 of the GDPR results from insufficient measures to ensure the security of processed data. Deliberations No. SAN-2019-006 of June 13, 2019, No. SAN-2019-007 of July 18, 2019, and No. SAN-2022-018 of September 8, 2022, specifically target the insufficient robustness of passwords.⁴⁵ Furthermore, the restricted formation recalls that securely storing passwords constitutes a basic precaution in terms of personal data protection. As early as 2013, ANSSI warned and reminded good practices regarding password storage by indicating that they should "be stored in a transformed form by a one-way cryptographic function (hash function) that is slow to compute, such as PBKDF2" and that "the transformation of passwords must involve a random salt to prevent an attack using precomputed tables" (ANSSI, "CERTA-2013-ACT-046 News Bulletin," November 15, 2013, <https://www.cert.ssi.gouv.fr/actualite/CERTA-2013-ACT-046/>).⁴⁶ Similarly, in its deliberation No. 2017-012 of January 19, 2017, CNIL already indicated that it "recommends [that the password] be transformed using a non-reversible and secure cryptographic function (i.e., using a well-known strong public algorithm whose software implementation is free of known vulnerabilities), incorporating the use of a salt or key." Indeed, non-robust hash functions present known vulnerabilities that do not guarantee the integrity and confidentiality of passwords in the event of a brute force attack after the servers hosting them have been compromised.⁴⁷ The restricted formation notes that, in this case, the passwords of users of the website www.neosurf.com had to be, at the time of the checks, composed of six characters from three types and lacked any complementary security measure.⁴⁸ It considers that such a construction did not allow for the security of the data and prevented unauthorized third parties from accessing it. The restricted formation recalls that, as the rapporteur pointed out, the company was processing, at the time of the on-site inspection, data from nearly 700,000 user accounts, such as name, first name, date of birth, email address, postal address, phone number, but also banking details (when the user decides to link an electronic wallet) or identity and residence documents (when a payment exceeds a certain amount). However, authentication relying on the use of a the user; or 3° is strictly necessary for the purpose of carrying out the transmission of a communication over an electronic communications network.⁵⁹ The restricted formation notes that the company did not provide clear and complete information to users regarding the purposes of accessing stored information on their electronic communication devices, nor did it inform them of the means available to oppose such access.⁶⁰ Consequently, the restricted formation considers that the company has failed to comply with the obligations set out in Article 82 of the Data Protection and Freedom Act.⁶¹ In light of the above, the restricted formation concludes that the company has not sufficiently demonstrated compliance with its obligations under the GDPR and the Data Protection and Freedom Act, particularly regarding the security of personal data and the transparency of data processing activities.⁶² The restricted formation emphasizes the importance of implementing robust security measures and ensuring that users are adequately informed about their rights and the processing of their personal data.

The user ".⁵⁹ These provisions transpose into French law Article 5, paragraph 3, of Directive 2002/58/EC of the European Parliament and of the Council of July 12, 2002, concerning the processing of personal data and the protection of privacy in the electronic communications sector (hereinafter referred to as the "e-Privacy Directive").

1. On the deposit of Google Analytics cookies on the user's terminal without obtaining their consent.⁶⁰ The rapporteur notes that during the online inspection, the delegation found the deposit of thirteen

cookies before any action by the user upon their arrival on the homepage of the website www.neosurf.com, among which were audience measurement cookies from Google Analytics, which should have been subject to the user's prior consent.⁶¹ In defense, the company initially argued during the proceedings that the Google Analytics cookie was an internal audience measurement tool exempt from the requirement to obtain consent, before acknowledging the facts in its defense observations and announcing that it no longer uses this tool. It provides a document certifying that as of August 16, 2023, Google Analytics cookies are no longer deposited on the terminals of users of the neosurf website and application.⁶² The restricted formation recalls that Article 82 of the Data Protection Act provides that operations to access or store information on a user's terminal can only take place after the user has expressed their consent, with only cookies that have the sole purpose of enabling or facilitating electronic communication or those strictly necessary for the provision of an online communication service at the express request of the user being exempted from this obligation.⁶³ The restricted formation considers that it follows from the documentation published online by the company GOOGLE that, on the one hand, depending on the settings chosen by the publisher of the concerned site, Google Analytics cookies may include advertising features and that, on the other hand, regardless of the settings chosen regarding the aforementioned advertising features, the data collected via Google Analytics cookies may be reused to maintain and protect the Analytics service.⁶⁴ Therefore, the restricted formation considers that the deposit of these cookies is subject to the prior collection of the user's consent, as they do not have the sole purpose of enabling or facilitating electronic communication and are also not strictly necessary for the provision of a service expressly requested by the user.⁶⁵ Consequently, the restricted formation considers that by allowing the deposit and reading of the Google Analytics cookie on the terminals of individuals upon their arrival on the website www.neosurf.com, without obtaining their prior consent, the company deprived them of the possibility, granted to them by Article 82 of the Data Protection Act, to make a choice regarding the deposit of trackers on their terminal equipment.⁶⁶ The restricted formation notes that the company has demonstrated during the proceedings that since August 16, 2023, no Google Analytics cookie has been deposited on the terminals of users. It nevertheless recalls that the compliance measures adopted cannot exempt the company from its liability for the past.

2. On the use of the Google reCaptcha mechanism without obtaining the user's consent.⁶⁷ The rapporteur notes that the company used the Google reCaptcha module in order to block bots on the registration and login page of the neosurf website and mobile application. He considers that the use of the module without prior consent from the user is contrary to Article 82 of the Data Protection Act, as it does not fall under any of the exemptions provided for by this article.⁶⁸ In defense, the company does not...

does not contest the facts described by the rapporteur, but indicates that it has remedied the shortcomings noted in the report by submitting the use of reCaptcha to the prior consent of the user and by not placing any cookies or trackers on their device in the event of refusal. The company adds that GOOGLE's reCaptcha has been definitively replaced by another solution at the end of October 2023. However, it believes that in light of the poorly readable and inaccessible information provided by GOOGLE regarding the consequences related to the use of the reCaptcha service, it would be unfair to impose breaches of Article 82 of the Data Protection Act on its client companies, without taking into account the lack of transparency and accessibility of the contractual information provided by GOOGLE, which has already been condemned by the CNIL for these reasons (CNIL n°SAN-2019-001 of January 21, 2019, and n°SAN-2021-023 of December 31, 2021). Consequently, it requests a reduction in the proposed fine.

69. In this case, the restricted panel notes that a reCaptcha mechanism, provided by GOOGLE, is used during the creation of an account and when logging into the neosurf website and mobile application. It considers that it is indeed the publisher of the site - in this case, NS CARDS FRANCE - that chose to use the reCaptcha mechanism and thus allowed the reading and writing actions of the information present on the users' devices.

70. In light of these elements, the restricted panel considers that the company is not justified in

claiming that it would be unfair to impose breaches of Article 82 of the Data Protection Act on GOOGLE's client companies, of which it is a part, by invoking the lack of transparency and accessibility of GOOGLE's contractual terms. Indeed, the restricted panel considers that as a user company of Google's reCaptcha service, the company is also responsible for complying with the provisions of the Data Protection Act when using this mechanism.

71. Secondly, the restricted panel considers that while a data controller may invoke an exemption from informing and obtaining consent when the reading/writing operations performed on a user's device have the sole purpose of securing an authentication mechanism for the benefit of users (see in this sense, CNIL, FR, Deliberation n° SAN-2021-013, cited above), the situation is different when these operations also pursue other purposes that are not strictly necessary for the provision of a service. However, the Google reCaptcha mechanism does not have the sole purpose of securing the authentication mechanism for the benefit of users but also allows for analysis operations by Google, which the GOOGLE company itself specifies in its general terms of use.

72. The restricted panel notes that GOOGLE informs companies using reCaptcha technology, in general terms of use available online, that the operation of the reCAPTCHA API relies on the collection of material and software information (such as data on devices and applications) and that this data is transmitted to Google for analysis. GOOGLE also specifies that it is the responsibility of these companies to inform users and to request their permission for the collection and sharing of data with GOOGLE.

73. It follows from these elements that NS CARDS FRANCE should have obtained the consent of users for the use of reCaptcha, which was not the case in this instance.

74. In light of the above, the restricted panel considers that by using the reCaptcha mechanism provided by GOOGLE without obtaining their consent, the company has violated the provisions. the processing, the restricted formation notes that the company NS CARDS FRANCE did not respect this principle, which is essential for ensuring that personal data is not kept longer than necessary for the purposes for which it is processed.⁸¹ Regarding the violation of the principle of data minimization, the restricted formation observes that the company collected more data than was necessary for its operations, which constitutes a significant breach of the GDPR principles.⁸² The restricted formation also emphasizes that the lack of prior consent from users for the processing of their data is a serious infringement, as it undermines the fundamental rights of individuals to control their personal information.⁸³ In light of these considerations, the restricted formation concludes that the proposed administrative fine must reflect the seriousness of the violations committed by the company.⁸⁴ The restricted formation decides to impose an administrative fine of 200,000 euros, taking into account the company's annual turnover and the need for the penalty to be effective, proportionate, and dissuasive.⁸⁵ The restricted formation also orders the company to implement corrective measures to ensure compliance with the GDPR and to prevent future violations.

****Conservation of Personal Data****

The company has demonstrated negligence by merely deactivating user accounts it retained instead of anonymizing or deleting the data they contained. In any case, assuming it was applied, the declared retention period of ten years during the inspections was not accompanied by any sorting between data to be retained and data to be deleted, as confirmed by the company during the hearing. The restricted panel notes that this failure potentially concerns a significant number of individuals, with the company claiming approximately 700,000 users having an account at the time of the inspections.

****Obligation to Inform Affected Individuals and Transparency****

Regarding the failure to inform affected individuals and to ensure transparency, the restricted panel notes that the company failed to provide complete and transparent information to the affected individuals, which is an essential prerequisite for this type of processing of personal data.

****Obligation to Ensure Security of Personal Data****

Concerning the failure to ensure the security of personal data, the restricted panel emphasizes the

number of breaches observed regarding basic security obligations, namely, the use of an insufficiently robust password for user accounts containing, for some, banking details, and the hashing of passwords using an outdated function. The restricted panel believes, like the rapporteur, that the accumulation of these security deficiencies by a company offering online payment solutions and collecting highly personal data has contributed to the fact that said data did not sufficiently benefit from the protection offered by the GDPR.

****Cookies Placed on User's Terminal****

Regarding the failure related to cookies placed on the user's terminal during the visit to the company's website, the restricted panel considers that the lack of consent collection affected each individual who visited the website in question, necessarily involving several hundred thousand people, given that the company claimed approximately 328,186 unique visitors to its website between September 2020 and September 2021. It also notes that the use of Google's reCaptcha module without prior consent from the user potentially concerned at least the 700,000 account holders at the time of the inspections.

****Responsibility for Past Breaches****

Finally, while taking into account that the company has implemented measures following the notification of the sanction report, the restricted panel notes that these actions do not exempt the company from its responsibility for the breaches that occurred in the past. Consequently, the restricted panel considers that an administrative fine should be imposed for the breaches of Articles 5-1-e), 12, 13, and 32 of the GDPR and Article 82 of the Data Protection Act.

****On the Amount of the Administrative Fine****

The restricted panel first notes that the breaches of Articles 5-1-e), 12, and 13 of the GDPR constitute breaches of key principles of the GDPR that may be subject, under Article 83 of the GDPR, to an administrative fine of up to 20,000,000 euros or up to 4% of annual turnover, with the higher amount being retained. The restricted panel then recalls that administrative fines must be effective, proportionate, and dissuasive. It emphasizes that the company NS CARDS FRANCE achieved a turnover of approximately [...] euros in 2020, with a net result of [...] euros. The restricted panel takes note that the rapporteur dismissed the breach related to the sharing of access accounts to the database and that the company does not contest the other breaches mentioned in the report.

Thus, in light of the company's responsibility, its financial capabilities, and the... relevant criteria of Article 83 of the Regulation, the restricted formation considers that an administrative fine of 90,000 (ninety thousand) euros for breaches of Articles 5-1-e), 12, 13, and 32 of the GDPR and an administrative fine of 15,000 (fifteen thousand) euros for breaches of Article 82 of the Data Protection Act appears justified.

B. On Publicity

89. The company contests the rapporteur's proposal to make this deliberation public, invoking in particular the protection of business secrets related to its contractual obligations under the contract concluded with the electronic money issuing establishment.

90. The restricted formation considers that the publicity of this decision is justified in light of the seriousness of the breaches involved and the number of individuals affected. It also believes that the publicity of the sanction will notably inform all individuals concerned by the breaches. Finally, regarding the argument related to the disclosure of business secrets, it recalls that information pertaining to business secrets is redacted from its published decisions.

91. Finally, the measure is proportionate in that the decision will no longer specifically identify the company after a period of two years from its publication.

FOR THESE REASONS

The restricted formation of the CNIL, after deliberation, decides to:

- impose an administrative fine of ninety thousand euros (90,000 €) against the company NS CARDS

FRANCE for breaches of Articles 5-1-e), 12, 13, and 32 of Regulation (EU) No. 2016/679 of April 27, 2016, on data protection;

- impose an administrative fine of fifteen thousand euros (15,000 €) against the company NS CARDS FRANCE for breach of Article 82 of the amended Law of January 6, 1978;
- make public, on the CNIL website and on the Légifrance website, its deliberation, which will no longer specifically identify the company after a period of two years from its publication.

The President

Alexandre LINDEN

This decision may be subject to an appeal before the Council of State within two months from its notification.